BSC (HONS) COMPUTER SCIENCE (SOFTWARE ENGINEERING)

MAL3018 COMPUTING PROJECT

Name : Eu Jin Yang

Student No : BSSE2506021

Project Name : PhishLens: An Explainable Machine Learning-Based Phishing and Scam Detection System for Gmail

---

Name of Supervisor : Ts. Mohd Khairi Bin Kamaruddin

Date : 10/09/2026

1. **Project Title**

   PhishLens: An Explainable Machine Learning-Based Phishing and Scam Detection System for Gmail

2. **Keywords**

   Phishing Detection; Scam Detection; Explainable Artificial Intelligence (XAI); Machine Learning; Browser Extension; Email Security; Gmail; SHAP; Homograph Attack; Cybersecurity

3. **Links**

   Source Code: https://github.com/JustJin6/PhishLens.git

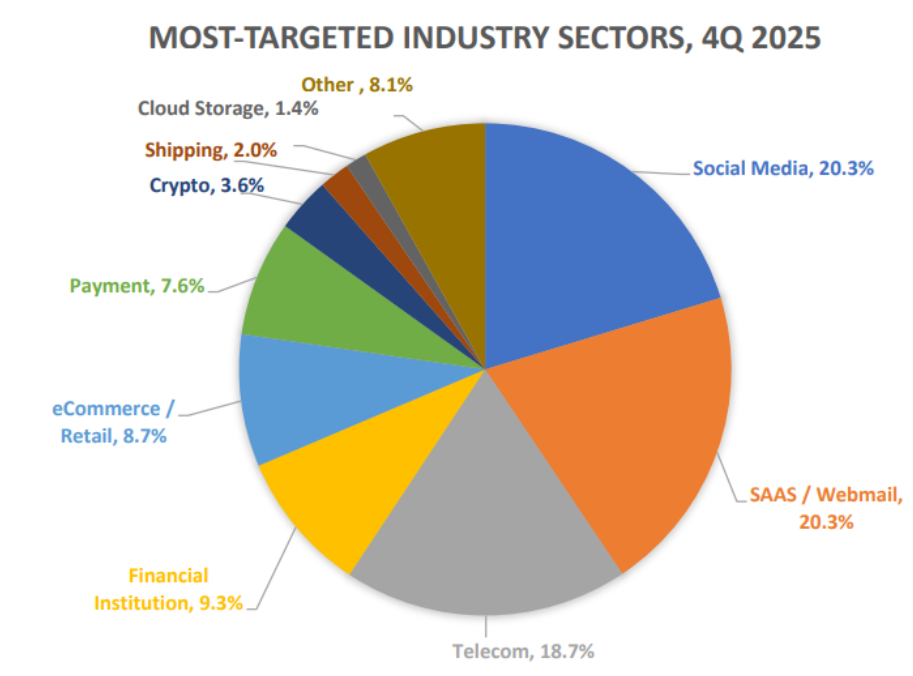
4. **Student Information**

   - **Name:** Eu Jin Yang
   - **Student ID:** BSSE2506021
   - **Programme / Major:** BSc (Hons) Computer Science (Software Engineering)
   - **Year / Semester:** Y3S2
   - **Email:** bsse2506021@peninsulamalaysia.edu.my

5. **Supervisor Information**

   - **Name:** Ts. Mohd Khairi Bin Kamaruddin
   - **Department:** School of Technology and Engineering (SOTE)
   - **Email:** khairi@peninsulacollege.edu.my

6. Background and Problem Statement



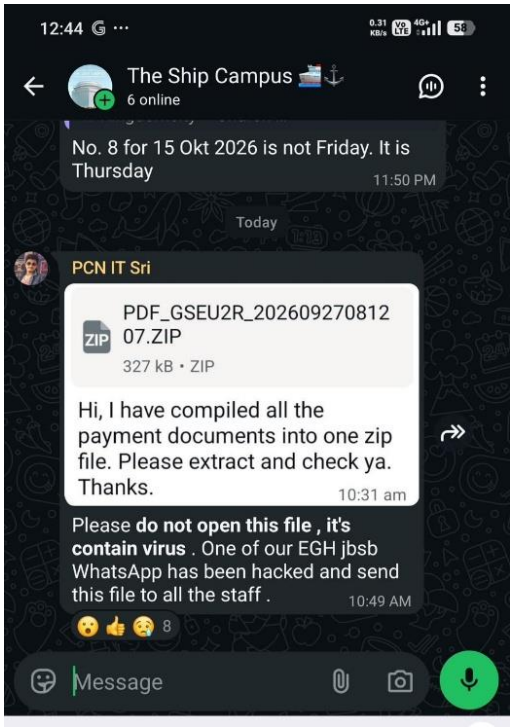
(Figure 6.0: Most Targeted Industry Sector, Fourth Quarter 2025)

(APWG, 2026)

Phishing and online scam emails are still one of the most persistent and financially damaging cyber threats that are faced by both individuals and organizations. In the worldwide, the Anti-Phishing Working Group (APWG) recorded approximately 3.8 million phishing attacks in 2025, which slightly increase from 3.76 million in 2024 (APWG, 2026). The Social Media and SaaS / Webmail categories were accounted for the largest share of attacks in the fourth quarter of the year, as presented in Figure 6.0 (APWG, 2026). This indicates that webmail platforms such as Gmail and Outlook are among the most frequently targeted attack surfaces.

At the national level, the problem is equally and even more serious. Malaysia's scam-related losses reached approximately RM2.7 billion in 2025, a 76% increase from 2024. The national Cyber999 Incident Response Center reported that in the third quarter of 2025, phishing and online scams accounted for approximately 75% of all incidents handled by the center (BERNAMA, 2026). Separately, Kaspersky ranked Malaysia as the third-most targeted country in Southeast Asia for phishing attacks, with over 64,000 recorded attack attempts between 2023 and mid-2025, and losses exceeding 7.5 million due to Business Email Compromise (BEC) scams (The Vibes, 2025).

A single successful phishing email is often enough to trigger a larger-scale security incident. In July 2025, OutcomesOne, a Florida-based healthcare technology company, suffered a phishing attack that lasted one hour. Although only one employee's email account was compromised, the incident resulted in the exposure of protected health information for nearly 150,000 people (Rankiteo, 2025). This case illustrates that security breaches almost always stem from the moment when a user opens and trusts a deceptive email, and that is precisely the moment this project aims to intervene.



(Figure 6.1: WhatsApp Warning Regarding a Suspected Malicious ZIP Attachment)

Recently, in an incident at Entrepreneur Growth Hub (EGH), a JBSB employee's WhatsApp account was compromised, and someone used that account to distribute a ZIP file disguised as a payment document, as shown in Figure 6.1. A warning issued to employees stated that the file contained a virus, and managers reported that the incident also affected the company's email environment. This illustrates how malicious attachments can spread through trusted workplace communication channels. While this is relevant background information, PhishLens does not inspect WhatsApp messages or scan ZIP files. Its detection scope is limited to emails currently open in Gmail.



(Figure 6.2: Differences Between Cyrillic and Latin Letter)

(s.r.o, 2026)

Despite the scale of the problem, most existing anti-phishing defenses such as spam filters, blacklists, and browser-level warnings like Google Safe Browsing operate as binary block-or-allow systems. They rarely explain to the end user why a particular message has been flagged, which does little to help users identify similar threats independently in the future. Furthermore, unclear and overly broad rules can also misclassify legitimate emails, thereby eroding user trust. At the same time, attackers are increasingly avoiding the use of obviously malicious payloads and instead rely on social engineering and visual deception techniques such as registering lookalike domains using Unicode characters that are visually indistinguishable from Latin letters. For example, substituting the Cyrillic letter “a” (U+0430) for the Latin “a” (U+0061), a technique known as an IDN homograph attack, as shown in Figure 6.2 (Suzuki et al., 2019). Such strategies are specifically designed to evade traditional filters based on keywords or blacklists.

Who is the user? The system’s primary users are ordinary Gmail users who have not received professional cybersecurity training, which includes students and employees, who rely on email daily for personal or work-related communication and are the most common targets of the credential-theft and social-engineering scams as described above.

Currently, there is no easy-to-use, easy-to-understand, and real-time browser-based tool that can analyze the specific email a user has opened in their webmail inbox and clearly

explain, in plain language, why that email poses a risk, including by detecting deceptive links and sender domains rather than silently blocking or allowing the email without a reasonable explanation.

7. Objectives

a. Develop a browser extension that automatically detects and extracts the content of the email currently opened by the user in Gmail, without accessing or scanning the rest of the mailbox.

b. Develop a lightweight, interpretable machine learning model such as Logistic Regression, Random Forest, or Gradient Boosting. At this stage, deliberately avoiding transformer-based models. The chosen model can classify an opened email as phishing with an associated risk score.

c. Implement a module that detects deceptive or lookalike hyperlinks and sender domains name, which including substitutions of Unicode homographs (Confusable characters) such as replacing the Latin letter “a” with the Cyrillic letter “a” in a spoofed domain name.

d. Integrate an explainability layer such as SHAP, LIME, or transparent feature importance scoring to identify and highlight the specific words, links, or sender attributes that have the greatest impact on a particular risk classification.

e. Design a user interface overlay that visually highlights suspicious portions of the email directly within the Gmail interface and displays corresponding risk scores and plain-language explanation.

f. Evaluate the system’s detection performance, which includes its accuracy, precision, recall, F1-score, and false-positive rate, against benchmark phishing / legitimate email datasets and, where possible, compare its performance with existing comparable tools.

8. Scope of the Project

In-Scope	Out-of-Scope
• Gmail web interface, accessed via desktop browser (Google Chrome) as the primary target platform • Analysis limited to the single email the user currently has open (Sender, subject, body text, and embedded hyperlinks) • A lightweight, interpretable machine learning model (non-transformer) • An explainability output that highlights suspicious content and states the reason for the risk score • Detection of homograph / lookalike-character substitutions in URLs and sender domains • A trusted-sender exclusion (whitelist) feature • Evaluation using established public phishing and legitimate email datasets	• Bahasa Melayu language (Reserved as a future work once the English version is stable) • Native mobile application or mobile-browser support (Browser extensions are desktop-only) • Full inbox or bulk email scanning (Only the currently opened email is analyzed) • Microsoft Outlook (Web) integration (Reserved as a future extension once the Gmail version is stable) • Automatic blocking, deletion, or quarantining of emails (The system only flags and advises) • Detection of non-email-based scams such as SMS (Smishing), voice (Vishing), or social media scams • Full sender-authentication header analysis such as SPF / DKIM / DMARC (Noted as possible future enhancement)

(Table 8.0: In-Scope and Out-of-Scope)

9. Literature Review / Related Works

5 related works were reviewed to position this project against the existing state of the art, spanning deployed browser extensions, offline explainable-AI research, and a specialized homograph-detection technique.

Study / Tool	Detection Target / Context	ML / Detection Approach	Explainability	Key Limitation / Gap

MailTrout: A Machine Learning Browser Extension for Detecting Phishing Emails (Boyle & Shepherd, 2021)	Phishing emails, browser extension / webmail environment	BLSTM using TensorFlow / Keras	No dedicated XAI explanation	Browser-based email detection, but not a Gmail-integrated feature-explanation system
NoPhish: Efficient Chrome Extension for Phishing Detection Using Machine Learning Techniques (Thaqi et al., 2026)	Phishing websites / URLs	RF, SVM, KNN, 22 features	Limited, MDI / Permutation feature importance, no user-facing local explanation	Website-focused rather than opened-email analysis, no user-facing local XAI
Explainable Machine Learning for Phishing Site Detection: A High-Efficiency Approach Using Boosting Models and SHAP (Uddin et al., 2025)	Phishing websites / URLs	GBM / XGBoost / LightGBM boosting models	SHAP (Strong, feature-level)	Strong XAI, but no live email / browser deployment
Demystifying Phishing Detection: Using Explainable AI to Identify Suspicious Email Features (Gangrade & Sivasamy, 2026)	Phishing emails, offline dataset analysis	TF-IDF + Logistic Regression	SHAP, LIME, and attention visualization	Strong explainability but evaluated offline, not integrated into a live webmail interface
ShamFinder: An Automated Framework for Detecting IDN Homographs (Suzuki et al., 2019)	IDN homograph domains	SimChar homoglyph database + Visual similarity	Pinpoints the differing characters	Homograph detection is isolated rather than integrated into an email phishing pipeline

(Table 9.0: Comparison of Related Works in Phishing Detection, Explainability, and Homograph Detection)

Within the 5 reviewed works, there is no single system that was identified that combines all three characteristics:

- Real-time browser-based analysis of the user's opened email
- Feature-level explainability

- Dedicated Unicode homograph detection

MailTrout demonstrates browser-based machine learning detection for phishing emails, while NoPhish demonstrates browser-based machine learning detection for phishing webpages. However, neither provides the user-facing, per-prediction explanation proposed by this project within a Gmail email-analysis context. Explainable Machine Learning for Phishing Site Detection and Demystifying Phishing Detection demonstrate the value of explainable machine learning for phishing detection using SHAP and related methods, but their evaluation is not integrated into the live Gmail browser environment targeted by this project. ShamFinder addresses Unicode IDN homograph detection as a specialised problem, but it is not integrated with a broader email phishing-detection pipeline. In short, the contribution of this project lies in combining these three elements, a browser-based detection pipeline for individual emails, paired with a lightweight and interpretable interpretation layer, and a dedicated homograph / lookalike-character module, and integrating them into a Gmail extension.

10. Methodology

a. Project Approach / Framework

An Agile-Scrum, iterative approach will be used, naturally split into two semesters:

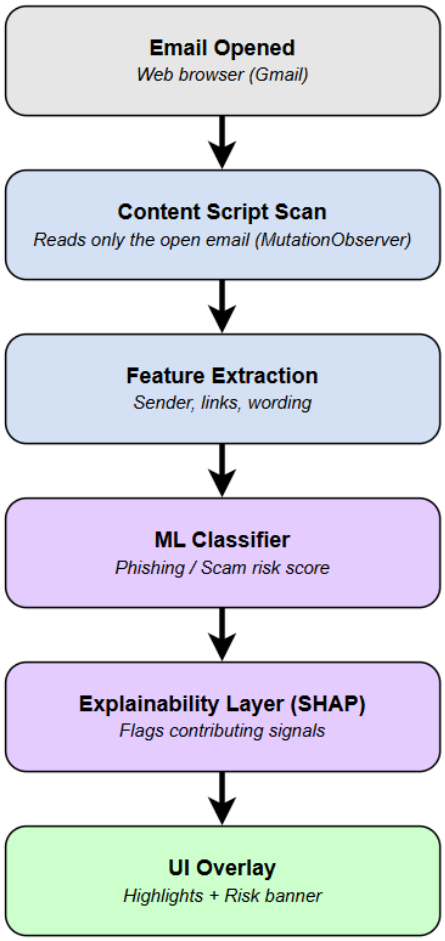
- 1st semester will cover the literature review, system design, data preparation, and initial model development.
- 2nd semester will cover extension development, full system integration, testing, and documentation.

b. Tools and Technologies

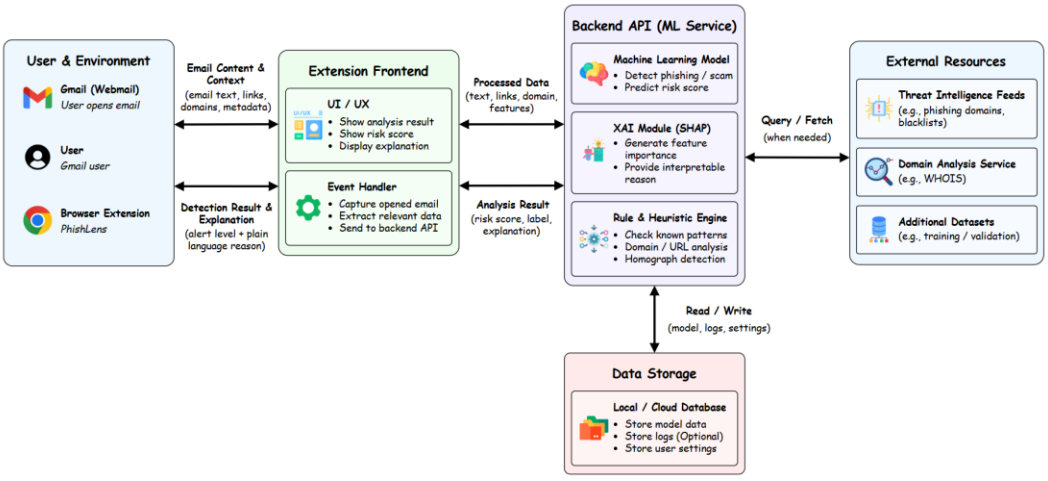
Python 3.x, scikit-learn, XGBoost / LightGBM, SHAP, and pandas / NumPy for model development; JavaScript, HTML / CSS, and Chrome's Manifest V3 Extension APIs for the browser extension; Git / GitHub for version control; Visual Studio Code as the development environment; Google Chrome (Developer Mode) for testing.

c. System Design / Architecture

The 2 diagrams below, as shown in Flowchart 10.0 and Flowchart 10.1 summarize the end-to-end detection pipeline, from the moment an email is opened in Gmail through to the highlighted, explained risk output shown to the user.



(Flowchart 10.0: System Diagram)



(Flowchart 10.1: Block Unit Diagram)

d. Implementation Plan

   The system will be built as 6 modules:

   i. A Content Script / DOM Parser Module (Detects and extracts the opened email)
   ii. A Feature Extraction Module (Derives lexical, sender, and link features)
   iii. A ML Inference Module (Runs the trained classifier)
   iv. A Homograph Detection Module (Flags Unicode confusable-character domains)
   v. An Explainability Module (Computes SHAP-based feature attributions)
   vi. A UI Overlay Module (Renders the highlights, risk score, and explanation inside Gmail)

e. Testing and Evaluation

   i. Unit testing will validate individual feature-extraction functions
   ii. The trained model will be evaluated on a held-out test set using accuracy, precision, recall, F1-score, and false-positive rate
   iii. A small-scale usability walkthrough with test users on curated sample emails will check that the surfaced explanations are understandable to a non-technical audience

11. Expected Deliverables

a. A working Chrome browser extension prototype for Gmail (Source code and an installable unpacked build)
b. A trained, documented machine learning phishing classifier, including the saved model artifact
c. An explainability module integrated into the extension's user interface (Highlighted spans, textual reasoning, and risk score)
d. A homograph / lookalike-character domain detection module
e. Technical documentation covering system architecture, data dictionary, and a model card
f. A final FYP report presenting the system design, implementation, and evaluation results

12. Risk Plan

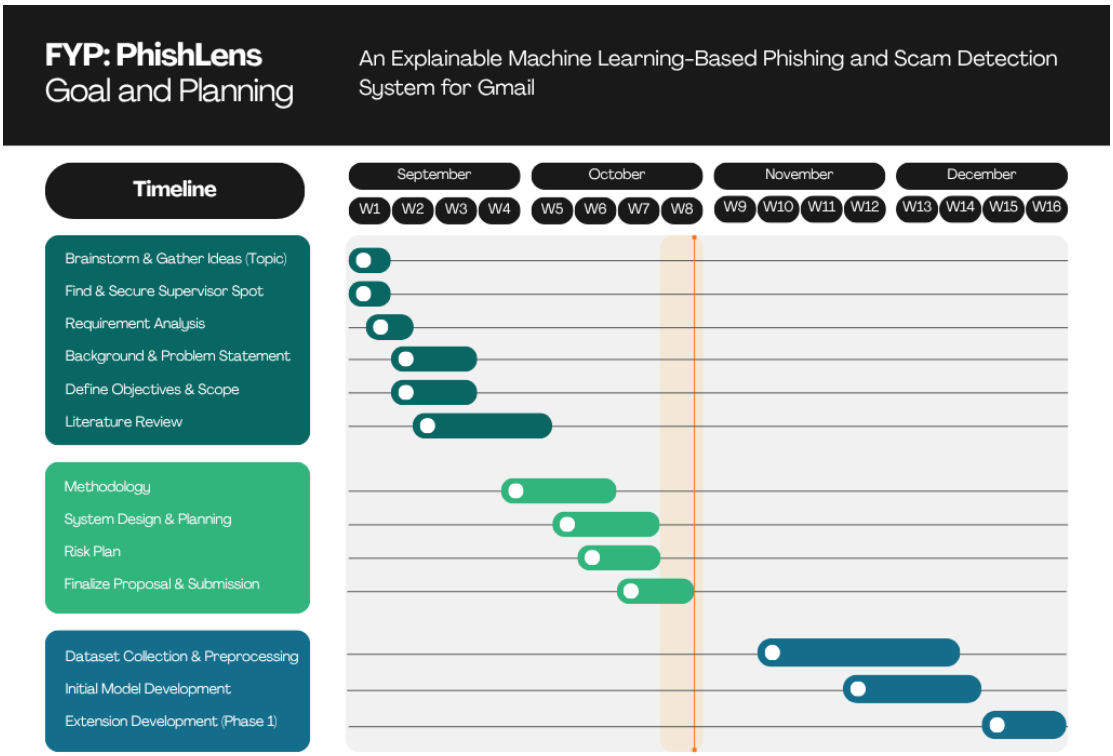
Risk	Likelihood	Impact	Mitigation Strategy
Gmail's DOM structure changes after a Google UI update, silently breaking the extension's element selectors.	Medium	Medium	Modularize all DOM selectors into a single configuration file, monitor Gmail changes during development, build defensive queries with fallback selectors.
The model produces too many false positives / negatives, undermining user trust or missing real threats.	Medium	High	Tune the classification threshold using validation data, report false-positive rate explicitly, allow user feedback (whitelist / report) to refine future iterations.
Handling real email content raises data-privacy and ethical concerns.	Medium	High	Run inference locally in the browser wherever feasible, avoid transmitting raw email content externally, document data handling clearly in the final report.
Public phishing / legitimate email datasets are limited or outdated relative to current tactics.	Medium	Medium	Combine multiple datasets (Nazario, Enron-Spam, PhishTank, Kaggle), clearly document dataset limitations in the evaluation section.
Model inference is too slow to run smoothly inside a browser extension.	Low	Medium	Use lightweight, non-transformer models only, benchmark inference latency early and optimize feature extraction if needed.
Project scope expands beyond what is achievable in the available timeline (scope creep).	Medium	High	Strictly follow the in-scope / out-of-scope boundaries defined in Section 8, treat Outlook support as an optional stretch goal only.
Chrome Web Store review / publishing is delayed or rejected.	Low	Low	Demonstrate and submit the extension in unpacked developer mode, treat public Web Store publishing as optional.

Ethical constraints prevent testing on real user's live inboxes with real phishing emails.	Medium	Medium	Use sandbox / test Gmail accounts populated with dataset-derived sample emails, follow the university's ethics approval process for any human usability testing.

(Table 12.0: Risk Assessment and Mitigation Plan)

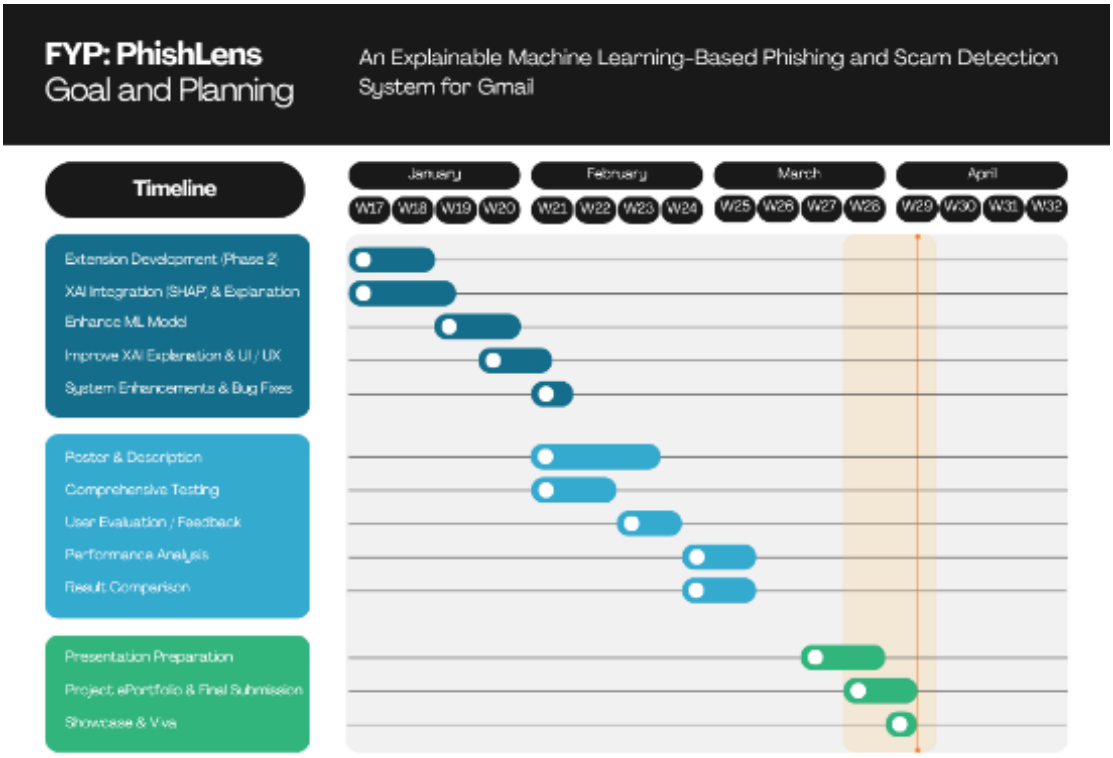
13. Proposed Gantt Chart

Phase 1 (September – December)



(Figure 13.0: Phase 1 Gantt Chart)

Phase 2 (January – April)



(Figure 13.1: Phase 2 Gantt Chart)

14. Resources Required

Category	Resource	Purpose
Hardware	Personal laptop / PC (8GB+ RAM recommended)	Development, model training, and testing
Software	Python 3.x, scikit-learn, XGBoost / LightGBM, SHAP, pandas / NumPy	Data processing and model development
	Visual Studio Code	Extension and model code development
	Google Chrome (Developer Mode)	Loading and testing the unpacked extension
	Git / GitHub	Version control and backup
Account / Fee	Chrome Web Store developer registration (One-time, ~USD $5 / RM20-25)	Only required if publishing the extension publicly

Datasets	Nazario Phishing Corpus, Enron-Spam Dataset, PhishTank, Kaggle phishing datasets	Model training and evaluation
Reference Material	Academic papers and APWG/industry threat reports	Literature grounding and benchmarking

(Table 14.0: Resources Required)

15. Expected Outcomes and Significance

Academically, this project provides an applied case study that combines a lightweight, interpretable machine learning model with real-world browser-based deployment to address a high-impact security problem, which directly addressing the gap that identified in Section 9, where explainability and live single-email deployment are rarely combined in existing work.

Practically and socially, given that Malaysia recorded approximately RM2.7 billion in scam losses in 2025, with phishing and online fraud making up roughly 75% of Cyber999-reported incidents in the third quarter alone (BERNAMA, 2026), a free, locally deployable safeguard embedded directly in the webmail client a user already relies on has clear practical value.

In terms of user trust, the system aims to help users gradually develop the ability to identify phishing emails over time by explaining why an email is considered risky, rather than silently deciding whether to block or allow it. This directly addresses the criticism of “black-box” filters repeatedly mentioned in Section 9.

Target Audience: Users who use Gmail daily (students, lecturers, professionals, and small business owners) will gain access to a free explainable AI protection measure. Moreover, the academic community will receive a case study combining explainable AI with real-time browser deployment. More broadly, national-level efforts to curb the scale of fraud losses described in Section 6 will also benefit from such free, user-education-oriented tools.

16. References

APWG. “Apwg_trends_report_q4_2025 V22.” Phishing Activity Trends Report Quater 4th, February 18, 2026. https://docs.apwg.org/reports/apwg_trends_report_q4_2025.pdf.

BERNAMA. “Kerugian Penipuan Di Malaysia Cecah RM2.7 Bilion Pada 2025, Memuncak Ketika Perayaan – Fortinet.” BERNAMA, March 24, 2026. https://bernama.com/bm/news.php?id=2536971.

Boyle, Paul, and Lynsay A. Shepherd. “*MailTrout*: A Machine Learning Browser Extension for Detecting Phishing Emails.” July 1, 2021, 104–15. https://doi.org/10.14236/ewic/HCI2021.10.

Codepoints. “U+0061 LATIN SMALL LETTER A: A – Unicode.” Codepoints.Net, 2026. https://codepoints.net/U+0061?lang=en.

Codepoints. “U+0430 CYRILLIC SMALL LETTER A: A – Unicode.” Codepoints.Net, 2026. https://codepoints.net/U+0430?lang=en.

Gangrade, Mrunal, and Shalini Sivasamy. *Demystifying Phishing Detection: Using Explainable AI to Identify Suspicious Email Features*. Springer Nature, 2026.

GROUP, ANTI-PHISHING WORKING. “APWG Year in Review: Scams Explode in 2025 via Social Media, SMS, Email and QR Codes.” ACCESSWIRE Newsroom, February 23, 2026. https://www.accessnewswire.com/newsroom/en/computers-technology-and-internet/apwg-year-in-review-scams-explode-in-2025-via-social-media-sms-em-1139913.

Rankiteo. “Outcomes® - Cyber Scoring History.” Rankiteo, July 1, 2025. https://www.rankiteo.com/company/outcomesone/history.

s.r.o, Glueo. “IDN Homograph Attack — Unicode Domain Phishing Explained 🧰.” Punycoder, March 1, 2026. https://www.punycoder.com/idn-homograph-attack/.

Suzuki, Hiroaki, Daiki Chiba, Yoshiro Yoneya, Tatsuya Mori, and Shigeki Goto. “ShamFinder: An Automated Framework for Detecting IDN Homographs.” arXiv.Org, September 17, 2019. https://arxiv.org/abs/1909.07539v1.

Thaqi, Leand, Arbnor Halili, Kamer Vishi, and Blerim Rexha. “NoPhish: Efficient Chrome Extension for Phishing Detection Using Machine Learning Techniques.” arXiv.Org, September 1, 2024. https://arxiv.org/abs/2409.10547v1.

The Vibes. “Malaysia Suffers RM7.5 Million Losses from Business Email Compromise since 2023 – Kaspersky | Tech | The Vibes.” July 7, 2025. https://www.thevibes.com/articles/lifestyles/110211/malaysia-suffers-rm7.5-million-losses-from-business-email-compromise-since-2023-kaspersky.

Uddin, Khandaker Mohammad Mohi, Nitish Biswas, Sarreha Tasmin Rikta, Md Nur -A-Alam, and Rafid Mostafiz. “Explainable Machine Learning for Phishing Site Detection: A High-Efficiency Approach Using Boosting Models and SHAP.” *The Journal of Engineering* 2025, no. 1 (2025): e70110. https://doi.org/10.1049/tje2.70110.